

Chương 1

Phân tích bài toán

STT	Chức năng	Mô tả	Dữ liệu đầu vào
1	Khởi động ứng dụng	Khởi tạo backend API cục bộ, static frontend và mở giao diện desktop cho người quản trị.	hệ thống
2	Nhận diện máy chủ	Thu thập thông tin Windows Server, phiên bản hệ điều hành và profile rule phù hợp.	front-end
3	Chọn chiến lược rà quét	Cho phép người dùng chọn rà quét cấu hình CIS hoặc rà quét IIS CVE.	front-end
4	Rà quét cấu hình	Rà quét cấu hình Windows Server theo bộ rule quick/full, đối chiếu expected/actual và sinh kết quả.	front-end
5	Theo dõi tiến trình rà quét	Hiển thị trạng thái, phần trăm hoàn thành và rule đang được xử lý trong quá trình scan.	front-end
6	Xem báo cáo	Hiển thị tổng quan pass/fail/manual, danh sách rule, nhóm dịch vụ và bằng chứng kiểm tra.	front-end
7	Xuất báo cáo	Xuất hoặc tải báo cáo rà quét cấu hình từ dữ liệu report đã sinh.	front-end
8	Xem trước khắc phục	Tạo script PowerShell khắc phục cho các rule lỗi được chọn nhưng chưa thay đổi hệ thống.	front-end
9	Áp dụng khắc phục và rollback	Sao lưu, chạy script khắc phục, kiểm tra dịch vụ và rollback nếu trạng thái hệ thống không ổn định.	front-end
10	Rà quét IIS CVE	Chạy audit IIS/Windows Server bằng local check và Metasploit RPC tùy chọn, sau đó sinh report JSON/HTML.	front-end

Bảng 1.1: Danh sách chức năng chính

Mã chức năng	CN01		
Tên chức năng	Khởi động ứng dụng		
Mục đích sử dụng	Khởi tạo API cục bộ, frontend tĩnh và giao diện desktop để người dùng bắt đầu workflow.		
Dữ liệu đầu vào	hệ thống		
Đầu vào (input)	api_token: mã xác thực API cục bộ (string, tự sinh hoặc lấy từ biến môi trường) port: cổng API và frontend cục bộ (integer)		
Đầu ra (output)	app_url: đường dẫn giao diện desktop (string) api_status: trạng thái API (boolean)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	Hệ thống	Tạo token và khởi động local API
	STT	Thực hiện	Hành động
	2	Hệ thống	Phục vụ frontend đã build
	STT	Thực hiện	Hành động
	3	front-end	Mở giao diện với apiBase và apiToken
Luồng sự kiện phụ (thất bại)	đưa ra thông báo lỗi khởi động		

Bảng 1.2: Chức năng 01: Khởi động ứng dụng

Mã chức năng	CN02		
Tên chức năng	Nhận diện máy chủ		
Mục đích sử dụng	Thu thập thông tin Windows Server để chọn profile rule phù hợp trước khi rà quét.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	api_token: mã xác thực API cục bộ (string)		
Đầu ra (output)	computerName: tên máy (string) osCaption: tên hệ điều hành (string) osVersion: phiên bản hệ điều hành (string) buildNumber: số build (string) isServer: máy có phải Windows Server hay không (boolean) profileKey: profile rule được chọn (string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gọi API /api/inventory
	STT	Thực hiện	Hành động
	2	Hệ thống	Đọc thông tin hệ điều hành và build
	STT	Thực hiện	Hành động
	3	front-end	Hiển thị inventory và profile
Luồng sự kiện phụ (thất bại)	đưa ra thông báo lỗi tải inventory		

Bảng 1.3: Chức năng 02: Nhận diện máy chủ

Mã chức năng	CN03		
Tên chức năng	Chọn chiến lược rà quét		
Mục đích sử dụng	Cho phép người dùng chọn hướng xử lý chính: rà quét cấu hình Windows Server hoặc audit IIS CVE.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	scanType: loại rà quét, gồm config hoặc iis_msf (string)		
Đầu ra (output)	selected_workflow: workflow được chọn (string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Hiển thị hai lựa chọn rà quét
	STT	Thực hiện	Hành động
	2	front-end	Người dùng chọn loại rà quét
	STT	Thực hiện	Hành động
	3	front-end	Chuyển sang bước cấu hình tương ứng
Luồng sự kiện phụ (thất bại)	giữ lựa chọn mặc định là rà quét cấu hình		

Bảng 1.4: Chức năng 03: Chọn chiến lược rà quét

Mã chức năng	CN04		
Tên chức năng	Rà quét cấu hình		
Mục đích sử dụng	Rà quét cấu hình Windows Server theo rule CIS, so sánh giá trị thực tế với giá trị mong muốn và sinh báo cáo.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	profileKey: profile rule Windows Server (string) mode: quick hoặc full (string) scanId: mã phiên rà quét (string)		
Đầu ra (output)	total: tổng số rule (integer) passed: số rule đạt (integer) failed: số rule lỗi (integer) manual: số rule cần kiểm tra thủ công (integer) items: danh sách kết quả rule (array) reportFile: đường dẫn report JSON (string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gửi POST /api/scan
	STT	Thực hiện	Hành động
	2	Hệ thống	Tải rule theo profile và chế độ scan
	STT	Thực hiện	Hành động
	3	Hệ thống	Thu thập registry, secedit, auditpol, local user và PowerShell
	STT	Thực hiện	Hành động
	4	Hệ thống	Đối chiếu expected/actual và ghi report
	STT	Thực hiện	Hành động
	5	front-end	Nhận kết quả và chuyển sang màn hình báo cáo
Luồng sự kiện phụ (thất bại)	đưa ra thông báo SCAN_FAILED		

Bảng 1.5: Chức năng 04: Rà quét cấu hình

Mã chức năng	CN05		
Tên chức năng	Theo dõi tiến trình rà quét		
Mục đích sử dụng	Cập nhật tiến trình để người dùng biết rule hiện tại, số lượng đã xử lý và phần trăm hoàn thành.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	scanId: mã phiên rà quét (string)		
Đầu ra (output)	status: trạng thái scan (string) total: tổng số rule (integer) completed: số rule đã xử lý (integer) percent: phần trăm hoàn thành (number) currentRule: rule đang chạy (object) recentRules: rule vừa hoàn thành (array)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gọi /api/scan/progress theo scanId
	STT	Thực hiện	Hành động
	2	Hệ thống	Đọc trạng thái tiến trình trong bộ nhớ
	STT	Thực hiện	Hành động
	3	front-end	Cập nhật thanh tiến trình và rule đang chạy
Luồng sự kiện phụ (thất bại)	giữ trạng thái hiện tại và tiếp tục polling		

Bảng 1.6: Chức năng 05: Theo dõi tiến trình rà quét

Mã chức năng	CN06		
Tên chức năng	Xem báo cáo		
Mục đích sử dụng	Hiển thị kết quả rà quét theo tổng quan, nhóm dịch vụ và chi tiết từng rule để phục vụ đánh giá bảo mật.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	reportFile: file báo cáo đã sinh (string) profileKey: profile rule (string)		
Đầu ra (output)	summary: thống kê pass/fail/manual (json) serviceTree: cây nhóm dịch vụ/rule (json) ruleDetails: chi tiết từng rule và bằng chứng (array)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gọi /api/report và /api/service-tree
	STT	Thực hiện	Hành động
	2	Hệ thống	Tải report mới nhất và dựng cây dịch vụ
	STT	Thực hiện	Hành động
	3	front-end	Hiển thị dashboard, nhóm dịch vụ và chi tiết rule
Luồng sự kiện phụ (thất bại)	đưa ra thông báo REPORT_UNAVAILABLE hoặc SERVICE_TREE_FAILED		

Bảng 1.7: Chức năng 06: Xem báo cáo

Mã chức năng	CN07		
Tên chức năng	Xuất báo cáo		
Mục đích sử dụng	Cung cấp báo cáo đã sinh để người quản trị hoặc kiểm toán viên lưu trữ và đối chiếu.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	format: định dạng xuất báo cáo, ví dụ html (string)		
Đầu ra (output)	report: nội dung báo cáo hoặc đường dẫn file (json/string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gọi /api/report/export
	STT	Thực hiện	Hành động
	2	Hệ thống	Đọc báo cáo mới nhất
	STT	Thực hiện	Hành động
	3	front-end	Nhận dữ liệu báo cáo để lưu hoặc hiển thị
Luồng sự kiện phụ (thất bại)	đưa ra thông báo REPORT_UNAVAILABLE		

Bảng 1.8: Chức năng 07: Xuất báo cáo

Mã chức năng	CN08		
Tên chức năng	Xem trước khắc phục		
Mục đích sử dụng	Sinh script PowerShell cho các rule lỗi được chọn để người dùng xem xét trước khi áp dụng.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	apply: false (boolean) selectedRuleIds: danh sách rule lỗi được chọn (array)		
Đầu ra (output)	scriptPath: đường dẫn script preview (string) applied: số rule có thể tự động khắc phục (integer) skipped: số rule bị bỏ qua (integer) requiresReview: yêu cầu người dùng xác nhận (boolean)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gửi POST /api/reconfig với apply=false
	STT	Thực hiện	Hành động
	2	Hệ thống	Tải report và lọc các rule FAIL được chọn
	STT	Thực hiện	Hành động
	3	Hệ thống	Sinh script PowerShell an toàn để review
	STT	Thực hiện	Hành động
	4	front-end	Hiển thị hộp xác nhận trước khi áp dụng
Luồng sự kiện phụ (thất bại)	đưa ra thông báo RECONFIG_FAILED		

Bảng 1.9: Chức năng 08: Xem trước khắc phục

Mã chức năng	CN09		
Tên chức năng	Áp dụng khắc phục và rollback		
Mục đích sử dụng	Thực thi script khắc phục sau khi người dùng xác nhận, có sao lưu và rollback khi kiểm tra dịch vụ thất bại.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	apply: true (boolean) selectedRuleIds: danh sách rule lỗi được chọn (array)		
Đầu ra (output)	ok: kết quả áp dụng (boolean) backupId: mã bản sao lưu (string) backupPath: đường dẫn sao lưu (string) autoRolledBack: có rollback tự động hay không (boolean) stdout, stderr: log thực thi (string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gửi POST /api/reconfig với apply=true
	STT	Thực hiện	Hành động
	2	Hệ thống	Tạo backup registry/cấu hình liên quan
	STT	Thực hiện	Hành động
	3	Hệ thống	Chạy script PowerShell khắc phục
	STT	Thực hiện	Hành động
	4	Hệ thống	Kiểm tra trạng thái dịch vụ sau khắc phục
	STT	Thực hiện	Hành động
	5	front-end	Hiển thị kết quả áp dụng
Luồng sự kiện phụ (thất bại)	rollback từ backup và đưa ra thông báo lỗi		

Bảng 1.10: Chức năng 09: Áp dụng khắc phục và rollback

Mã chức năng	CN10		
Tên chức năng	Rà quét IIS CVE		
Mục đích sử dụng	Rà quét các vấn đề IIS/Windows Server bằng local check và Metasploit RPC tùy chọn, có giới hạn an toàn cho active test.		
Dữ liệu đầu vào	front-end		
Đầu vào (input)	target: IP hoặc hostname mục tiêu (string) activeTest: bật/tắt kiểm thử chủ động (boolean) ports: danh sách cổng kiểm tra (array) selectedCves: danh sách CVE được chọn (array)		
Đầu ra (output)	results: danh sách kết quả audit (array) reportFile: report JSON IIS CVE (string) htmlReportFile: report HTML IIS CVE (string)		
Luồng sự kiện chính (thành công)	STT	Thực hiện	Hành động
	1	front-end	Gọi /api/msf/modules và /api/msf/status
	STT	Thực hiện	Hành động
	2	front-end	Gửi POST /api/msf/audit
	STT	Thực hiện	Hành động
	3	Hệ thống	Validate target, port và CVE
	STT	Thực hiện	Hành động
	4	Hệ thống	Chạy local check hoặc Metasploit RPC khi cần
	STT	Thực hiện	Hành động
	5	Hệ thống	Ghi report JSON/HTML
	STT	Thực hiện	Hành động
	6	front-end	Hiển thị kết quả IIS CVE
Luồng sự kiện phụ (thất bại)	đưa ra thông báo INVALID_TARGET, MSF_RPC_UNAVAILABLE hoặc MSF_AUDIT_FAILED		

Bảng 1.11: Chức năng 10: Rà quét IIS CVE